



INK MORROW 5.0 DEVELOPMENT EDITION

Security, Privacy & AI Boundary

What crosses the threshold, what stays local, and who remains in control

For operators, players, and security reviewers / September 2026

Security, Privacy & AI Boundary

01 5.0 resistance is not a security boundary

A character's refusal is a game-design contract, not an access-control mechanism for the real application. Story text, pleas and claimed authority cannot write the application-owned challenge decision directly. Evidence must exist as recorded world state, but models can still misinterpret how narrative evidence arose. Outcome-field and quotation checks are useful structural safeguards, not a proof of semantic consistency. Do not describe the system as immune to persuasion.

Private challenge motives, requirements and basis hashes are omitted from reader responses. Selected challenge definitions and relevant historical facts may enter the reviewed narrator context; they also belong in the private playable save, not reader-facing books. No new credentials, background calls or telemetry are added. World corrections remain explicit owner actions outside the fictional contest.

02 5.0 images and saves

Image upload and binary save import remain behind authentication, same-origin and CSRF checks before body parsing. Uploaded rasters are container-checked, pixel/byte bounded, stripped of metadata/animation and normalized. Image reads are story-scoped, authenticated and no-store. SVG, forged containers and broken digests fail closed.

Painting sends only the selected passage and art direction to the reviewed Illustrator; it does not send private facts, motives or uploaded references. Each press permits one attempt. A rejection after provider completion still records its known charge; uncertain dispatch is not reported free.

A playable save is unencrypted and contains spoilers, private motives and directions across all paths. It excludes credentials, provider configuration, consent and live request authority. Books exclude those private game surfaces altogether. Import has hard compressed/expanded bounds, validates all references and media, and creates a new copy transactionally without interpreting paths or storage keys from the file.

03 5.0 reader boundary

The new reader starts private requests only after unlock. Lock clears prose, cast, facts, input drafts and credential fields. Route epochs discard late UI responses; leaving a story does not pretend to cancel a provider request already dispatched. All story text is rendered with text nodes, not interpreted HTML. Secret facts and private correction reasons are excluded from normal story responses, but selected hidden truth is disclosed as part of the paid narrator's provider exposure.

The client submits the provider/model shown in review. A changed storyteller role rejects the request before purchase; replaying a completed key remains free even after configuration changes. Paid consent follows the existing remembered-device policy: a review is not necessarily shown on every later click. One request allows one billable attempt, and failures retain known charges. Estimates are not caps.

Ink Morrow is private-by-default self-hosted software, not a hosted confidentiality service. The owner chooses the machine, storage, network, provider, models, and publications. This book explains the trust boundaries those choices create and the controls built around them.

It is useful to authors because it says what leaves the machine. It is useful to operators because it says what must be protected. It is useful to reviewers because it names the threats and verification duties.

Security posture: one owner, loopback by default, same-origin application, explicit provider actions, immutable public snapshots, versioned transfer, and fail-closed identity/version checks.

Contents

5.0 resistance is not a security boundary

5.0 images and saves

5.0 reader boundary

Trust map

Data inventory

Authentication and browser boundary

Provider secrets

The AI boundary

Untrusted provider output

Continuity, models, and truth

Paid-operation safety

Upload security

Archive and import security

Public snapshot sharing

Network deployment

Threat register

Privacy decisions by workflow

Security operator checklist

Security change checklist

04 Trust map

```
PRIVATE MACHINE
  Browser <-----same origin-----> Ink Morrow process
                                   |-- SQLite and media
                                   |-- encrypted provider vault
                                   |
                                   +---- explicit request ----> AI provider
                                   +---- selected snapshot ---> HTTPS readers
                                   +---- reviewed archive ----> chosen storage
```

The browser, operating system account, filesystem backups, reverse proxy, provider account, and any public capability recipient are distinct trust decisions. Self-hosting removes a maintainer cloud; it does not make a compromised machine or leaked key safe.

05 Data inventory

Data	Normal home	May leave when
Manuscript prose	SQLite	AI context, publication, archive, public snapshot
Directions and prepared prose	SQLite private work state	Paid generation context or optional working-history archive
World/cast/Author Canon	SQLite	Relevant AI context, selected archive/publication metadata
Continuity evidence/corrections	SQLite	Relevant AI context or selected archive
Art/audio	Data directory	Reference/generation, publication, archive, public snapshot
Provider key	Environment or encrypted local vault	Sent only to configured provider endpoint as credential
Owner password/session	Local auth stores	Never a project archive/publication/provider payload
Share capability	Recipient URL; hash at rest	Whoever receives the URL
Recovery/undo credentials	Local data	Never portable archive/publication/share
Cost and provider traces	Local operation records	Sanitized diagnostics only when owner shares them

The application has no maintainer analytics, advertising, tracking pixels, or crash telemetry. An AI provider receives only because the owner invokes a provider-backed action or has enabled an explicit background preparation flow.

06 Authentication and browser boundary

Ink Morrow has one owner. Setup uses a terminal-printed one-time code, after which ordinary login creates a random opaque session whose stored representation cannot be used directly as the browser token. Successful authentication rotates identity; logout, expiry, and reset revoke it.

State-changing requests require a session plus CSRF token and Origin/Referer/Host checks. SameSite cookies, strict output encoding, content security policy, MIME-sniffing prevention, and frame restrictions add defense in depth.

Locking the interface is not disk encryption. Anyone with sufficient operating-system or backup access may copy the local data. Protect the user account and backup storage accordingly.

07 Provider secrets

Use a dedicated provider key with the least account privilege available and a hard upstream spending limit. The provider account is the authoritative cost boundary.

Environment keys are read-only to Ink Morrow but plain text in configuration. UI-entered persistent keys are encrypted in a separate vault. A random data-encryption key protects entries; the owner passphrase wraps that key under a purpose-separated derivation. Plaintext keys exist only in process memory while unlocked.

Password change rewraps the data key. Terminal password recovery cannot recreate the old wrapping key, so it clears saved provider credentials and requires re-entry while preserving manuscripts and media.

SECRET HANDLING

Provider keys must never appear in API responses, browser persistence, logs, screenshots, archives, publication files, public snapshots, test fixtures, issue reports, or Git history. Redact adjacent headers and provider error bodies as well as the obvious key string.

08 The AI boundary

Ink Morrow is designed for human-led, AI-collaborative writing. The author supplies intention, taste, direction, revision, and the final decision on canon. AI accelerates drafting, continuity extraction, optional impact summaries, imagery, and narration.

An action review should identify:

- provider and model;
- data categories being sent;
- selected image references;
- expected operation count;
- estimated cost; and
- whether equivalent consent may be remembered.

Repeated prompts should not become meaningless nuisance dialogs, but a new provider, data category, reference image, public publication, or destructive action requires renewed clarity.

OpenRouter is the only supplier tested with Ink Morrow. Other OpenAI-compatible endpoints may not offer compatible discovery, strict JSON, reasoning controls, imagery, or narration and may fail entirely.

09 Untrusted provider output

Provider output is input, not authority:

- generated prose is plain text, not executable HTML;
- continuity must satisfy a strict versioned JSON schema;
- unknown fields and missing evidence are rejected;
- model-supplied filenames, URLs, markup, and tool instructions are ignored;
- image bytes cross the same decode/normalization boundary as uploads;
- provider error bodies are bounded, sanitized, and redacted; and
- one provider response cannot invoke another paid action.

Prompt injection inside manuscript text cannot grant mutation authority. The server constructs role-separated requests and the resulting data crosses explicit application validation and transaction guards.

10 Continuity, models, and truth

The Archivist model is server-configured because automatic memory should not drift with browser-local preferences. An explicit invalid `CONTINUITY_MODEL` refuses startup before listening. This makes a typo visible instead of silently choosing a different cost/behavior profile.

The Main Character perspective anchor receives highest priority in a Main Character-driven manuscript, followed by support cast, background setting, and background cast. This bounds large prompts while preserving narrative identity.

AI-extracted memory never outranks the author. Author Canon and corrections are explicit, versioned overlays. Optional AI impact summaries can point at consequences but cannot apply a correction, retire a fact, or rewrite prose.

11 Paid-operation safety

Networks lose responses and users double-click. Each paid prose operation therefore has an idempotency key, expected manuscript/tail/revision, context fingerprint, one provider owner, durable result, known usage, and final state.

A retry joins or starts a traceable new attempt according to state. A stale result becomes superseded instead of mutating the changed story. Known spend is recorded even when canon does not advance. Partial provider streams never become canon.

Prepared prose is speculative and inert. The green Next Page action may promote only the exact prepared identity shown to the author; it cannot hide a replacement generation.

12 Upload security

"Upload any image" describes subject-matter freedom, not a parser bypass. Ink Morrow does not semantically classify the image. It does protect the system by:

- streaming multipart data to private staging;
- limiting compressed bytes and decoded pixels;
- verifying signatures and successful decode rather than trusting extension/MIME;
- using random storage names;
- producing a safe raster derivative and stripping EXIF/XMP/GPS metadata;
- fixing response type and disabling sniffing;
- rejecting or boundedly rasterizing active formats such as SVG; and
- cleaning staging after success, failure, timeout, cancellation, and restart.

An upload never triggers AI. A user must explicitly select an asset before it is transmitted as a reference.

13 Archive and import security

`.inkmorrow` archives are unencrypted ZIP containers with a declared manifest, ordinary JSON, and optional media. Treat them as confidential manuscript packages.

Import streams to staging and rejects traversal, backslashes, symlinks, duplicates, undeclared paths, excessive entry count, expansion/ratio bombs, unsafe IDs, hash mismatch, invalid media, unknown family, and future version before catalogue writes.

Preflight shows scope and collisions. Commit stages filesystem changes with rollback evidence and uses one SQLite transaction. Full replace first creates a safety archive. No provider call occurs during export, preflight, or import.

Portable archives never contain authentication records, sessions, provider credentials, saved paid consent, recovery/undo credentials, or share capabilities. Derived indexes are rebuilt.

14 Public snapshot sharing

A share is publication by capability, not access control around the live manuscript. Creation freezes an immutable normalized publication document. The random URL capability is stored only as a hash and is the reader's key.

Public reads:

- use GET/HEAD only;
- expose no private application ID or API;
- invoke no provider;
- receive `noindex`, `nofollow`, `noarchive`, strict referrer/CSP, frame denial, and MIME protections;
- fail closed after expiry or revocation; and
- do not change when the source manuscript changes.

HTTPS is required because it encrypts the capability and content in transit and authenticates the public front door. A loopback-only test origin is the narrow exception.

15 Network deployment

Loopback (`127.0.0.1`) accepts connections only from the same computer. It is the default and safest supported operating shape.

For other devices, use a reviewed HTTPS reverse proxy while Ink Morrow remains on loopback. The proxy must preserve Host, set the forwarded HTTPS scheme, forward authorization correctly, and never log or cache share tokens.

Direct plain HTTP on a LAN exposes traffic to that network path. `ALLOW_INSECURE_LAN=1` is an explicit temporary exception and cannot enable public shares. It should not become an Internet-facing configuration.

16 Threat register

Threat	Primary control	Evidence
Credential disclosure	Encrypted vault, redaction, exclusion	Secret canaries across responses/logs/exports
Cross-site mutation	CSRF + origin/referer/Host + session	Missing/foreign header integration tests
Session replay	Random opaque rotation, hash, expiry/revoke	Auth replay tests
Password guessing	Memory-hard derivation and throttling	Bounded authentication tests
Duplicate spend	Idempotency, one owner, durable operation	Concurrent/repeated-call tests
Stale reply	Expected context and superseded state	Reordered mock races
Prompt injection	Role separation, schema validation, no AI authority	Adversarial story fixtures
Archive attack	Streaming limits, path/hash/manifest checks	Malicious archive corpus
Image attack	Decode/pixel bounds, derivative, metadata strip	Polyglot/bomb/malformed fixtures
Stored script	Context-safe DOM rendering and CSP	XSS corpus
Capability leak	No logs/referrer/index; token hash; revoke	Canary URL and header tests
Private overpublication	Allowlist snapshot and exposure preview	Negative-field contracts
Filesystem escape	Explicit roots and stable random names	Traversal/symlink tests
Supply-chain compromise	Lockfiles, pinned Actions, audit/review	CI policy and dependency review

17 Privacy decisions by workflow

Draft or prepare prose

Relevant recent prose, compact memory, unresolved threads, selected local canon/cast/world context, and direction may go to the Scribe provider. The entire novel is not sent by design.

Build or repair memory

Page prose plus bounded relevant story/cast context goes to the configured Archivist. The structured result is stored locally with page/revision evidence.

Paint

Prompt and explicitly chosen reference images go to the selected image-capable provider. Local uploaded art does not leave the machine merely by existing in Gallery.

Narrate

Selected page/section text, voice, and model settings go to a narration-capable provider. Cached identical results can replay without another provider call.

Publish or share

No AI is required. The owner selects formats, metadata, and placed art. A share exposes only its frozen allowlisted reading copy.

Back up or restore

No AI is required. The portable exposure review names included history/media and excluded secrets. The archive remains unencrypted.

18 Security operator checklist

- Keep application and provider account credentials unique.
- Set provider-side hard spending limits.
- Restrict `.env` , `DATA_DIR` , logs, backups, and terminal history.
- Stay on loopback unless a reviewed network need exists.
- Use HTTPS for any remote access or public sharing.
- Keep Chrome, Node, OS, and reviewed dependencies updated.
- Restore-test backups in an isolated data directory.
- Revoke obsolete or possibly leaked share links.
- Report failures with sanitized diagnostics, never real keys/manuscripts unless deliberately minimized.

19 Security change checklist

5.0 release-branch playable-fiction boundary

All `/api/fiction` routes sit behind the existing owner, origin, Host and CSRF boundary. New stories and local state actions call no provider. A reply sends the story premise, selected cast descriptions and motives, boundaries, current control, episode, bounded recent text and relevant facts to the selected text provider. Relevant secret world facts may cross that provider boundary to support narration; reader-facing state responses omit secret facts and private correction reasons.

The model returns prose and evidenced state proposals. It may introduce a genuinely new named cast member with evidence, but cannot overwrite an existing person, transfer character control, change episode status, overwrite an existing fact, or invent a recorded commitment for an inhabited character without input evidence. These structural checks do not prove semantic fidelity of every generated sentence. The narration instructions and regression tests cover knowledge and control, while the owner retains a correction path. No statement here makes a provider trusted.

Paid work is idempotent, revision-checked, bounded to one successful provider completion per request, and charged honestly on local validation failure. There is no automatic paid follow-up. Complete 5.0 save portability is a later release batch; do not export these games with the older manuscript archive endpoints.

Private character motives and hidden facts stay out of normal reader responses. The authored-opening catalogue contains neither solutions nor private motives. Scene plans remain provisional provider guidance, not factual authority. The model can still make semantic mistakes despite structural validation. Adding cast members, correcting facts or changing preferences does not call a provider. There is no manual prose-writing feature. Fiction disables automatic transport retries and retains uncertain spend after dispatch or restart instead of silently treating it as zero.

A pull request changing authentication, provider calls, archives, uploads, publication, sharing, database identity, or network behavior must update its threat model and tests in the same change.

Block release when a supported path can lose/corrupt canon, disclose credentials/private prose, duplicate spend silently, accept stale mutation, escape upload/archive storage, expose mutable APIs publicly, or bypass authentication/CSRF/Host protections.

FINAL AUTHORITY

Ink Morrow can help the author think, draft, remember, paint, and narrate. It cannot decide what is canon, publish without a reviewed action, or make a provider trustworthy. Those decisions remain with the human owner.